

Disaster Recovery Plan for Drata

By Johanna Kougbéadjó

CMAP 660 – Organizational Resilience

06/16/2025

1. Introduction

This Disaster Recovery Plan (DRP) outlines Drata's strategy to restore critical business operations and IT systems in the event of a disruptive incident such as natural disasters, cyberattacks, or infrastructure failures. As a cloud-native SaaS platform supporting continuous compliance automation for standards like NIST, SOC 2, and ISO/IEC 27001. Drata is committed to ensuring service resilience, customer data protection, and business continuity.

2. System or organization description

Drata operates a multi-tenant SaaS platform hosted on Amazon Web Services (AWS). It supports a globally distributed customer base and integrates with third-party systems such as GitHub, AWS, and Google Workspace.

The core components of the system include a React-based single-page application (SPA) for the frontend and a suite of Node.js microservices deployed via Kubernetes for backend operations. Data storage is managed using a combination of AWS RDS (PostgreSQL) and DynamoDB, providing both relational and NoSQL capabilities. Continuous integration and deployment are handled through GitHub Actions, with Terraform facilitating infrastructure-as-code deployments. The security stack integrates tools such as CrowdStrike, AWS GuardDuty, and other SIEM solutions for threat detection and incident response.

Drata operates within a zero-trust, cloud-first environment. All services are containerized and governed by strict access control mechanisms, including single sign-on (SSO) and multi-factor authentication (MFA) via Okta. To ensure operational integrity, development, staging, and production environments are strictly segregated using IAM policies and network segmentation strategies (AWS, 2023).

3. Assumptions

Drata's disaster recovery planning is built on the assumption that its core infrastructure is hosted entirely on AWS, operating under the shared responsibility model, where AWS ensures the physical and foundational infrastructure and Drata is responsible for application-level security and configurations. Regular, encrypted backups of critical data are performed daily and stored securely across multiple AWS regions to ensure geographic redundancy and rapid retrieval.

Key personnel required for recovery activities are assumed to be reachable both during and outside of standard business hours, supported by on-call rotation schedules. The recovery site configurations and cloud fail-over mechanisms are validated and tested on a scheduled basis to confirm readiness. In addition, Drata's established incident response

protocols are fully integrated into the disaster recovery framework, providing a seamless transition from threat containment to infrastructure restoration.

4. Overview of IT Disaster Recovery Plan Phases

The DRP consists of three primary phases: (1) Activation and Notification, (2) Recovery, and (3) Reconstitution. These phases follow a sequential and coordinated process to minimize downtime, protect data integrity, and ensure a compliant return to operations in the event of a disaster.

Phase 1, Activation and Notification, focuses on the timely recognition of a disaster scenario, internal escalation through predefined criteria, and formal initiation of the DRP. This includes the identification of affected systems, stakeholder notification, and the activation of incident-specific communication and triage procedures (Swanson et al., 2010).

Phase 2, Recovery, encompasses the technical and operational steps required to bring critical systems and services back online. It involves restoring from verified backups, redeploying infrastructure, validating service inter-dependencies, and performing comprehensive testing. This phase is grounded in industry best practices, including those outlined by the National Institute of Standards and Technology (NIST) and the AWS Well-Architected Framework, ensuring both security and regulatory alignment (Amazon Web Services, 2023; Cichonski et al., 2012).

Phase 3, Reconstitution, begins once systems are restored and validated. This phase formalizes the transition back to steady-state operations. Activities include cleaning up temporary configurations, documenting recovery steps, reviewing performance metrics, and implementing improvements identified during the response. A post-incident debrief with executive stakeholders ensures accountability and drives continuous improvement in the organization's business continuity strategy (Kok-Boon Oh et al., 2022).

This phased structure enables Drata to align its disaster recovery operations with the ISO/IEC 27001:2022 standard, ensuring consistency, auditability, and resilience across its cloud-native SaaS infrastructure (ISO, 2022).

5. Roles and Responsibilities

Drata's Disaster Recovery Team (DRT) is a multidisciplinary group composed of key personnel across the organization, each selected for their operational function and expertise in managing cybersecurity and continuity events. The DRT is responsible for implementing the Disaster Recovery Plan.

The Disaster Recovery Manager (DRM) leads the activation of the plan and coordinates all related activities, ensuring consistent communication and documentation throughout the process. The DRM's role is central in maintaining operational oversight, mobilizing resources, and tracking progress across all recovery stages.

The Chief Information Security Officer (CISO) provides strategic oversight, ensuring that all recovery efforts align with Drata's enterprise risk management framework and compliance obligations such as SOC 2 and ISO/IEC 27001. The CISO also evaluates residual risk during and after recovery.

Engineering Leads execute the technical components of the recovery process. This includes initiating infrastructure fail-over, restoring essential services using Infrastructure-as-Code methods, re-establishing system connectivity, and validating restored environments for performance and stability.

The Security Operations Center (SOC) monitors the recovery environment for any lingering or new security threats. The SOC performs post-restoration assessments and vulnerability scans, confirming that no indicators of compromise remain and that the restored system meets Drata's security standards.

Legal and Compliance personnel are responsible for fulfilling regulatory obligations triggered by the incident. This includes coordinating communication with regulators, ensuring compliance with breach notification laws, and maintaining documentation to support audits or investigations.

The Communications Lead manages internal and external messaging, ensuring transparency and consistency. They coordinate with Legal, Executive Leadership, and Customer Success teams to issue timely updates to affected parties, helping maintain trust and manage reputational risk throughout the incident lifecycle.

6. Phase 1: Activation and Notification

This phase establishes a structured response protocol for initiating timely and effective action when critical systems are disrupted due to a disaster. It ensures that Drata activates its disaster recovery posture without delay, enabling containment and escalation workflows to protect business continuity. A prompt activation of the DRP is crucial as downtime may directly affect the company's financial well-being as well as customer trust.

By codifying this activation process into the DRP, Drata aligns its response capabilities with ISO/IEC 27001:2022 and NIST SP 800-34 Rev.1 best practices. These frameworks emphasize timely escalation, structured communication, and predefined severity criteria as critical components of operational resilience (ISO, 2022; Swanson et al., 2010).

6.1 Outage Assessment

The SOC and engineering teams conduct an immediate and collaborative technical triage to determine the scope, impact, and underlying cause of the outage. This assessment relies heavily on centralized telemetry pipelines, including real-time log aggregation (e.g., through tools like Datadog or Splunk), infrastructure monitoring dashboards, anomaly detection systems, and automated alerts triggered by defined thresholds in service-level indicators (SLIs).

Key elements of the assessment include identifying whether the disruption is localized or systemic, which services or user segments are impacted, the potential for data corruption or loss, and whether indicators of compromise suggest a security breach. Root cause hypotheses are generated based on historical baselines, automated detection logic, and known dependency maps.

As the severity and business impact become clearer, the findings are mapped to Drata's predefined Severity Classification Matrix, which dictates the escalation path, recovery resource allocation, and external notification requirements. This escalation may involve activating the DRP, initiating a cross-regional failover, or declaring an internal incident requiring cross-functional coordination. This structured approach aligns with both NIST SP 800-34 guidelines and ISO/IEC 27001:2022 clauses requiring timely risk identification and recovery prioritization (Swanson et al., 2010; ISO, 2022).

6.2 Activation Criteria and Procedures

The DRP is activated when specific criteria indicate a severe disruption to business-critical systems and infrastructure. One such scenario is a region-wide AWS failure, which directly impacts Drata's ability to deliver core platform functionality and access to customer-facing services. Such an event undermines both system availability and operational continuity, warranting immediate DRP initiation.

Another trigger is the unavailability of primary authentication services (such as the identity provider) for a duration exceeding 30 minutes. This directly compromises access management, which is foundational to Drata's zero-trust model and security posture. Similarly, any detection of database corruption or evidence of ransomware requires activation of the DRP, as these incidents pose a direct threat to data integrity and long-term availability.

Finally, if a business continuity risk is identified and it is likely that a contractual service-level agreement (SLA) will be breached, the DRP must be triggered to minimize operational downtime, protect customer trust, and meet regulatory obligations.

6.3 Notification Procedures

The Disaster Recovery Manager (DRM) is responsible for initiating the official declaration of a disaster recovery event. This declaration is broadcast across secure and redundant communication channels including encrypted Slack channels, SMS, and enterprise-grade email platforms. Notification templates are pre-configured to ensure consistency and speed of delivery. Real-time status updates are posted to a centralized incident management dashboard, which is integrated with Drata's IRP/DR Confluence space and the PagerDuty alerting platform.

Notification protocols require that all critical stakeholders (executive leadership, engineering, compliance, legal, communications, and customer support) are informed within 30 minutes of DRP activation. This rapid dissemination aligns with ISO/IEC 27001:2022 expectations for timely communication during business continuity events and ensures compliance with customer SLAs (ISO, 2022).

To prevent communication failure during infrastructure outages, Drata leverages mobile-first redundancy. SMS alerts are sent using Twilio Notify, which supports tiered escalation, while fallback video conferencing links (e.g., Zoom) are embedded in all notifications to enable immediate virtual coordination. This structured, multi-channel approach ensures that awareness is quickly established across the organization, allowing for synchronized response efforts and minimizing the risk of fragmented or delayed action (Swanson et al., 2010).

6.4 Escalation Notices/Awareness

If cloud service provider issues persist beyond predefined resolution windows or if the situation escalates to meet legal notification thresholds (e.g., affecting regulated data or services under NIST, SOC 2, or ISO/IEC 27001), Drata initiates external communications in alignment with its business continuity and compliance obligations. In such cases, escalation protocols involve contacting AWS Enterprise Support to initiate region-level diagnostics and resolution procedures. Drata's support SLAs with AWS ensure priority routing for critical-impact events (Amazon Web Services, 2023).

Simultaneously, the Legal and Compliance teams initiate engagement with cyber insurance providers to activate policy coverage and initiate claims processes if applicable. In parallel, the organization assesses whether breach notification laws under frameworks such as GDPR or CCPA are triggered, in which case regulators such as the CNIL or the U.S. Department of Health and Human Services are formally notified through predefined reporting templates and processes (ISO, 2022).

If backup restoration or incident response requires third-party vendor involvement, Drata's pre-vetted partners are onboarded immediately through Master Services

Agreements (MSAs) and non-disclosure agreements (NDAs). These partners include incident response specialists, forensic analysts, and managed service providers. These relationships are reviewed annually to ensure contractual and technical readiness. This multi-tiered escalation structure ensures continuity of service, legal compliance, and transparent stakeholder management during complex recovery scenarios (Swanson et al., 2010; Cichonski et al., 2012).

7. Phase 2: Recovery

The Recovery phase is the centerpiece of Drata's disaster response capability, encompassing all technical and operational activities required to bring business-critical services back online in a secure and validated manner. This phase prioritizes data integrity, system availability, and customer-facing functionality to meet defined Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO).

Restoration activities begin with the secure retrieval and verification of encrypted backups stored in AWS S3, leveraging cross-region replication and hash-based checksum validation. Drata's engineering teams utilize Infrastructure-as-Code (IaC) methodologies—primarily Terraform and CloudFormation—to redeploy infrastructure components with consistency and minimal human intervention. Microservices are brought back online in a phased sequence, starting with identity and access management systems, followed by core APIs and customer interfaces.

System interdependencies are tested through continuous integration/continuous deployment (CI/CD) pipelines that execute automated regression and integration testing. Tools like Datadog and AWS CloudWatch are used to monitor service health, and any anomalies are escalated through established observability channels.

Simultaneously, the SOC conducts forensic validation and vulnerability scanning to confirm no compromise persists within the recovered systems. These activities are conducted using industry-standard tools aligned with recommendations from NIST SP 800-34 and ISO/IEC 27001 Annex A.17 (Swanson et al., 2010; ISO, 2022).

Once full platform functionality is confirmed and security validation passed, the Recovery phase concludes with executive approval to proceed to Reconstitution. This phased and tightly controlled process ensures that Drata's DR efforts are aligned with compliance frameworks like NIST, SOC 2, and ISO/IEC 27001, while minimizing customer impact (Cichonski et al., 2012; Amazon Web Services, 2023).

7.1 Sequence of Recovery Activities

The sequence of recovery activities is structured to restore critical business operations securely and efficiently, following best practices outlined in NIST SP 800-34 Rev.1 (Swanson et al., 2010) and aligned with Drata's compliance posture under frameworks like ISO/IEC 27001 and SOC 2. This process begins with immediate integrity validation of system backups. Using cryptographic checksums and automated verification scripts, backup data is assessed to confirm that no corruption, tampering, or ransomware encryption has occurred during the outage window (Cichonski et al., 2012).

Once validated, the recovery team initiates the restoration of production environments from designated cross-region backups stored in encrypted Amazon S3 buckets. Drata maintains disaster recovery configurations for cross-regional fail-over between AWS us-east-1 and us-west-2 regions, following the principle of geographic redundancy to mitigate regional infrastructure failure risks (Amazon Web Services, 2023). Restoration workflows are orchestrated using Infrastructure-as-Code (IaC) tools, primarily Terraform and AWS CloudFormation, to enable rapid, consistent provisioning of network and compute resources.

The next stage involves the staged redeployment of platform-critical microservices. These include the customer-facing web application, authentication services (tied to SSO integrations like Okta), and internal APIs that enable evidence collection, risk scoring, and control monitoring. Each microservice is containerized and deployed via CI/CD pipelines with secure approval workflows to avoid reintroducing vulnerabilities.

Following deployment, the platform undergoes system-level reintegration checks. These tests validate service-to-service communication, API responsiveness, data layer functionality, and third-party integration integrity (e.g., GitHub, Slack, Jira). Any abnormalities are logged and triaged using observability tools like Datadog and internal error monitoring dashboards.

Security revalidation is conducted in parallel. The SOC initiates a post-recovery scan using dynamic application security testing (DAST) tools and cloud workload protection platforms (CWPP). This step ensures that no residual vulnerabilities or indicators of compromise remain from the initial incident (Kok-Boon Oh et al., 2022). Where required, short-term compensating controls (e.g., IP allowlists, token revocation, privilege reduction) are applied until full verification is achieved.

Only after successful functional and security testing is the environment declared stable. This ensures compliance with ISO/IEC 27001 control A.17.1.2, which mandates that critical business processes be restored to meet SLAs and protect data integrity following disruptive events (ISO, 2022).

7.2 Recovery Site

Drata maintains cloud-native recovery capabilities via its cross-region deployment architecture on AWS. In the event of a failure in the primary region (typically us-east-1), the platform is designed to fail over to a secondary region (e.g., us-west-2). These regions are geographically isolated to mitigate the risk of a single point of failure and to ensure redundancy at the physical infrastructure level. Recovery configurations are pre-deployed and validated quarterly to ensure readiness.

To meet high availability requirements, Drata leverages AWS's multi-AZ and multi-region fail-over services. Elastic Load Balancers and Route 53 DNS fail-over configurations enable automatic traffic redirection to the standby region once the disaster threshold is triggered. This approach ensures business continuity and aligns with the recommendations of the AWS Well-Architected Framework's Reliability Pillar (Amazon Web Services, 2023).

7.3 Alternate Storage Facility

Drata uses encrypted Amazon S3 buckets with cross-region replication (CRR) policies to store daily backups of all production workloads. These backups are encrypted using AWS KMS (Key Management Service) and validated using cryptographic checksums. The data is replicated across at least three Availability Zones within each region to meet durability objectives.

Backup retrieval is fully automated through secure API and CLI workflows that are tightly integrated with Drata's IaC framework. These workflows allow for scalable recovery processes and significantly reduce manual handling errors. Backup snapshots are versioned and include configuration metadata to allow full environment reconstruction when required (Swanson et al., 2010).

7.4 Alternate Data/Voice Telecommunications

To ensure resilient communication during DR events, Drata maintains alternate communication channels across voice, messaging, and conferencing platforms. In the event of a Slack or VoIP outage, fallback communications are handled via Zoom, Twilio (for SMS alerts), and direct mobile calling trees.

All DR stakeholders have been pre-enrolled in these alternate systems, and testing is conducted biannually to confirm availability and functionality. Critical incident coordination uses Twilio Notify and PagerDuty for mobile alerts and on-call scheduling. These tools ensure that communications continue uninterrupted even if the primary

system fails, aligning with ISO/IEC 27001:2022 requirements for communications continuity (ISO, 2022).

7.5 Data Validation and Functionality Testing

After restoration, Drata initiates a structured data validation and functionality testing protocol. This begins with automated data consistency checks across critical databases using hash comparisons and validation scripts. Once data integrity is confirmed, the platform undergoes a full regression test suite, including key user journeys and API endpoint verification.

Post-recovery security assurance includes DAST, configuration integrity validation, and sandbox-based behavioral tests. Penetration testing is conducted by internal or third-party experts to identify any post-restoration vulnerabilities. The goal is to meet RTO and RPO without compromising on service integrity or compliance (Cichonski et al., 2012).

8. Phase 3: Reconstitution

This phase focuses on returning operations to a steady state and securing the restored environment against future disruptions. It includes cleanup of temporary configurations, audit trail documentation, and strategic improvements.

8.1 Event Documentation

All actions taken during recovery are recorded in a centralized Confluence page maintained by the DRM. This includes system state snapshots, command logs, decisions made during the DR event, and timestamps. These records are reviewed post-incident to inform continuous improvement efforts and may be used in regulatory disclosures or audits.

Detailed logs are also captured in AWS CloudTrail and Splunk, with analysis used to cross-validate manual entries. This dual-record approach ensures both human-readable and machine-auditable trails of the incident (Kok-Boon Oh et al., 2022).

8.2 Deactivation

The DRM, in consultation with Engineering, Security, and Compliance leads, determines when the DR phase may be safely deactivated. The criteria include successful completion of all validation and testing steps, full restoration of service availability, and formal sign-

off from relevant stakeholders. The DRM ensures the reconstitution checklist is completed and documented.

Executive approval is required for the deactivation phase to formally close. A post-mortem review is scheduled within 48 hours of deactivation to discuss response effectiveness and identify improvement opportunities (Swanson et al., 2010).

9. Training And Testing Exercises

Regular training and simulation exercises are essential for maintaining an effective and reliable disaster recovery capability. This section outlines how Drata trains its personnel to respond to disaster scenarios and tests its recovery procedures through practical, controlled exercises. These efforts ensure that recovery processes are not only understood by all responsible stakeholders but also continuously improved based on empirical results.

9.1 Training

All technical personnel receive role-based DR training during onboarding, followed by annual refreshers. Training covers fail-over protocols, backup restoration, system validation, and DR communications procedures. Updates to infrastructure or incident response protocols prompt mandatory retraining.

To build organizational resilience, tabletop exercises are conducted semi-annually with cross-functional participation, simulating various DR scenarios such as ransomware, regional outages, and data corruption. These exercises are designed in collaboration with external advisors and red teams when applicable.

9.2 Testing

Drata conducts full end-to-end DR simulations twice per year. These include failover to alternate AWS regions, simulated data loss recovery, and verification of communication channels. Each test is followed by a formal after-action review where lessons learned are logged, and corrective actions assigned.

Success criteria include meeting target RTO and RPO metrics, full system recovery, no data integrity violations, and effective coordination among all involved roles. DR tests are documented as audit artifacts to support ISO/IEC 27001 and SOC 2 compliance.

10. Document Management

Effective document management ensures the DRP remains accurate, up to date, and securely accessible to authorized personnel. This section defines who is responsible for maintaining the DRP, how and when the document is reviewed, and the mechanisms used to control access and distribution. Proper management of this documentation is vital not only for operational readiness but also for demonstrating compliance with regulatory and audit requirements.

10.1 Document Ownership

The Vice President of Engineering is the designated DRP owner and is accountable for ensuring its alignment with Drata's ISMS and broader business continuity planning. The owner ensures cross-functional input and sign-off during major revisions.

10.2 Plan Review and Maintenance

The DRP is reviewed quarterly or after significant system architecture changes, DR events, or audit findings. Reviews are logged in Confluence, with version history maintained. Updates are coordinated by the VP of Engineering and validated by the Security and Compliance teams.

10.3 Document Distribution

The most current version of the DRP is stored in a restricted-access Confluence repository with access granted to authorized stakeholders. Backup copies in PDF format are version-controlled and archived securely in AWS WorkDocs.

APPENDICES

Appendix A: Personnel Contact Data

Name	Role	Department	Email	Phone (Primary)	Phone (Backup)	Time Zone	On-Call
Samantha Brooks	Disaster Recovery Manager	IT Operations	s.brooks@drata.com	+1-415- 555-0101	+1-415- 555- 0199	PST	Yes
David Renner	CISO	Security	d.renner@drata.com	+1-415- 555-0102	+1-415- 555- 0103	PST	Yes
Marisa Tan	Engineering Lead	DevOps	m.tan@drata.com	+1-415- 555-0104	+1-415- 555- 0105	PST	Yes
Lena Choudhury	SOC Manager	Security	l.choudhury@drata.com	+1-415- 555-0106	+1-415- 555- 0107	PST	Yes
Jerome Carter	Legal Counsel	Legal	j.carter@drata.com	+1-415- 555-0108	+1-415- 555- 0109	PST	No
Teresa Nguyen	Communications Lead	Corporate Affairs	t.nguyen@drata.com	+1-415- 555-0110	+1-415- 555-0111	PST	No

Appendix B: Call Tree

DRM (Samantha Brooks) initiates the call tree upon DRP activation. The order is as follows:

1. Samantha Brooks notifies David Renner (CISO) and Marisa Tan (Engineering Lead).
2. David Renner notifies Lena Choudhury (SOC) and Jerome Carter (Legal).
3. Marisa Tan notifies DevOps team.
4. Lena Choudhury notifies SOC analysts.
5. Teresa Nguyen is notified by Samantha Brooks for communications support.

Each member must confirm contact and notify their downstream within 15 minutes. If unreachable, a secondary contact will escalate. The entire call process must complete within 45 minutes of DRP activation.

Appendix C: Personnel Contact Data – Vendors

Vendor Name	Service Type	Contact Person	Email	Phone (24/7)	Portal URL	Contract Ref
Amazon Web Services	Cloud Infrastructure	Sarah Lin	s.lin@aws.amazon.com	+1-866-555-1000	https://aws.amazon.com/support	AWS-MSA-2022
CloudGuard	MDR/Threat Intel	Roberto Silva	roberto@cloudguard.io	+1-800-555-2233	https://console.cloudguard.io	CG-SOC-001
LegalTrust LLP	Breach Counsel	Nina Ward	nina.ward@legaltrust.com	+1-800-555-3311	https://secure.legaltrust.com	LT-BR-2021
DataVault	Backup Storage Vendor	Kevin Young	k.young@datavault.net	+1-855-555-4400	https://portal.datavault.net	DV-MSA-009
Insight IR	Incident Response Team	Sofia Ortega	sortega@insightir.com	+1-888-555-8899	https://insightir.com/client-access	IIR-DR-021

Appendix D: Outage Assessment Checklist

The following checklist is used during the Activation and Notification Phase to assess the scope and severity of the outage and determine whether Disaster Recovery Plan (DRP) activation is warranted. This checklist should be completed by the Disaster Recovery Manager (DRM), in collaboration with the Security Operations Center (SOC) and Engineering leads, within 30 minutes of outage detection.

Incident Information

- **Detection Timestamp:** _____
- **Detection Source:** (e.g., Datadog alert, CloudWatch metric, support ticket)
- **Reporting Team or Individual:** _____
- **Affected Services/Systems:** _____
- **User Groups Impacted:** (e.g., internal only, customer-facing, multi-region)

Initial Technical Assessment

- **Root Cause Hypothesis:**
 -
- **Scope of Impact:**
 -
- **Dependencies Affected:**
 -

Business and Compliance Impact

- **Potential SLA Violation:**
 - Estimated duration until breach: _____ minutes/hours
- **Customer Impact Detected:**
 -
- **Data Security Concern:**
 -

Initial Severity Classification

- **Severity Level:**
 -

DRP Activation Decision

- Rationale: _____
- DRM Signature: _____
- Timestamp: _____

Communication Log

Timestamp	Notified Party	Role	Channel (Slack, SMS, etc.)	Acknowledged?
	Samantha Brooks	DRM	Slack	☐ Yes ☐ No
	David Renner	CISO	SMS	☐ Yes ☐ No
	Marisa Tan	Engineering	Slack	☐ Yes ☐ No
	Lena Choudhury	SOC Lead	SMS	☐ Yes ☐ No

Appendix E: Detailed Recovery Procedures

1. Retrieve latest verified backups from S3 Glacier vaults.
2. Launch failover AWS region via Terraform module (drata-main.tf).
3. Rebuild VPCs, IAM policies, and DNS routing for region.
4. Restore encrypted EBS volumes and attach to EC2 instances.
5. Restart service containers: auth, app-core, telemetry, frontend.
6. Deploy CI/CD jobs to re-validate infrastructure and app builds.
7. Monitor system health with CloudWatch and Datadog integrations.
8. Perform automated smoke testing of user and admin workflows.
9. Execute security scans (AWS Inspector, Snyk, custom DAST tools).
10. Approve go/no-go status after consensus by DRM, CISO, and Engineering.

Appendix F: Data Validation and Functionality Testing Procedures

1. Run SHA-256 hash validation against restored MySQL and MongoDB data.
2. Cross-check user access logs and transaction logs for discrepancies.
3. Sample 200 records per service and manually inspect edge cases.
4. Execute automated test suites for all APIs (auth, audit, automation).
5. Validate frontend functionality via Selenium and Postman scripts.
6. Benchmark average response time and error rate to baseline.
7. Conduct DAST scans using OWASP Zap and verify remediation steps.
8. Engage Insight IR red team if attack vector was confirmed.
9. Complete validation checklist and submit for CISO and DRM sign-off.

References

Amazon Web Services. (2023). *AWS Well-Architected Framework – Reliability Pillar*.
<https://docs.aws.amazon.com/wellarchitected/latest/reliability-pillar>

Amazon Web Services. (2023). Disaster Recovery of Workloads on AWS.
<https://docs.aws.amazon.com/pdfs/whitepapers/latest/disaster-recovery-workloads-on-aws/disaster-recovery-workloads-on-aws.pdf#disaster-recovery-workloads-on-aws>

Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (2012). *Computer security incident handling guide* (NIST SP 800-61 Rev. 2). National Institute of Standards and Technology.
<https://doi.org/10.6028/NIST.SP.800-61r2>

International Organization for Standardization. (2022). *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection – Information security management systems – Requirements*. ISO.

Kok-Boon Oh, B., Ho, B., & Slade, B. (2022). *Cybersecurity risk management: An ERM approach*. Nova Science Publishers.

Swanson, M., Bowen, P., Phillips, A., Gallup, D., & Lynes, D. (2010). *Contingency planning guide for federal information systems* (NIST SP 800-34 Rev. 1). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-34r1>

International Organization for Standardization (ISO). (2022). *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection – Information security management systems – Requirements*. ISO.